UNIT 1 · TOPIC 1.1

Social Engineering

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A teacher receives an email from "do-not-reply@g00gle.com" asking them to click a link to approve a student's document-access request. Which detail is the strongest indicator that this message is a phishing attempt?

- ○ A. The email mentions a student by relationship rather than by name
- **● B. The sender domain "g00gle.com" substitutes zeros for the letter O in "google"**
- ○ C. The email was sent during school hours
- ○ D. The subject line uses an exclamation point

Correct answer: B

Why: A lookalike domain that swaps characters to imitate a trusted brand (typosquatting) is one of the most reliable technical indicators of phishing, since legitimate organizations don't send mail from spoofed domains.

*Why the others are wrong: **A**, Vague references to a "student" without a name are a soft social-engineering cue but far less definitive than a forged domain. **C**, Timing alone says nothing about legitimacy; plenty of real institutional email arrives during school hours. **D**, Urgent punctuation is a manipulation tactic, not a technical indicator, students often overweight tone and underweight the sender address.*

2. An attacker calls an employee, claims to be from the IT helpdesk, and references the employee's manager by name before asking for a password reset. Which social engineering tactic is this?

- **● A. Pretexting**
- ○ B. Tailgating
- ○ C. Baiting
- ○ D. Phishing

Correct answer: A

Why: Pretexting involves inventing a fabricated scenario or identity, here, a fake IT role bolstered by real-sounding detail, to build false trust and extract information over a direct interaction such as a phone call.

*Why the others are wrong: **B**, Tailgating is physically following someone through a secured door, not a phone-based ruse. **C**, Baiting lures victims with an enticing physical or digital item (like a USB drive), not an invented identity. **D**, Phishing specifically refers to deceptive messages, typically email, rather than a live phone impersonation.*

3. A worker badges into a secure office building, holding the door open for a person carrying boxes who has no visible ID badge. What social engineering risk does this scenario illustrate?

- ○ A. Quid pro quo
- ○ B. Vishing
- ○ C. Whaling
- **● D. Tailgating**

Correct answer: D

Why: Tailgating (or piggybacking) is gaining unauthorized physical access by following an authorized person through a secured entry point, exploiting politeness rather than a technical flaw.

*Why the others are wrong: **A**, Quid pro quo involves offering a service in exchange for information or access, not simply following someone through a door. **B**, Vishing is voice-based phishing over phone calls, unrelated to physical entry. **C**, Whaling is phishing targeted specifically at senior executives, not a building-access scenario.*

4. In the phishing email scenario, the message states: "Research shows that the faster teachers respond to students' document-sharing requests, the more likely students are to submit assignments on time." Why does this sentence make the email more persuasive?

○ A. It explains the technical steps required to share a document

○ B. It proves the sender is affiliated with an educational research organization

● C. It cites a believable-sounding justification that pressures the teacher to act quickly without verifying the request

○ D. It confirms the student's identity to the teacher

Correct answer: C

Why: This sentence manufactures false urgency by framing inaction as harmful to students, exploiting the teacher's sense of responsibility to short-circuit careful verification, a classic influence tactic in social engineering.

*Why the others are wrong: **A**, The sentence is about urgency and consequence, not instructions. **B**, An unverified claim in an email proves nothing about the sender's actual affiliation; that's exactly the point of the manipulation. **D**, Nothing in that sentence identifies any specific student; it speaks only in generalities.*

5. An attacker leaves a USB drive labeled "Q4 Salary Review, Confidential" in an office break room. Why is this tactic likely to succeed in getting an employee to plug it in?

○ A. It requires the employee to enter a password before the attack works

○ B. It directly exploits a software vulnerability without any user action

○ C. It relies on the employee already trusting the attacker personally

● D. It exploits curiosity and the perceived value of confidential information to override caution

Correct answer: D

Why: Baiting works by dangling something the target wants, here, sensitive salary information, so curiosity or self-interest overrides normal caution about unknown devices.

*Why the others are wrong: **A**, No password entry is needed for a USB-based baiting attack to execute. **B**, Baiting requires the victim to take an action (plugging in the drive); it isn't an automatic exploit. **C**, Baiting works precisely because it doesn't require any prior relationship with the attacker.*

6. If the teacher in the scenario had clicked the link and entered their school login credentials on the resulting page, what is the most likely organizational impact?

○ A. The teacher's device is permanently disconnected from the network

○ B. The school's email server automatically resets all passwords

● C. The attacker gains access to the teacher's account and any systems or data it can reach

○ D. No impact occurs unless the teacher also opens an attachment

Correct answer: C

Why: Credential harvesting through a fake login page gives the attacker working credentials, enabling account takeover and lateral access to whatever data, email, or shared systems that account can reach, the central impact social engineering attacks are designed to produce.

*Why the others are wrong: **A**, Compromise typically grants access rather than cutting off connectivity. **B**, There is no automatic system-wide reset triggered by an individual phishing click. **D**, Credential theft itself is the harmful action; no separate attachment is required for the impact described.*

7. A school IT administrator is documenting the phishing incident with the teacher's email for a post-incident report. Which combination of evidence most strongly supports classifying this as a targeted phishing attempt rather than generic spam?

○ A. The email contained no links and only requested a reply

○ B. The email was sent to one teacher and used formal language

● **C. The email used a spoofed lookalike domain, referenced a plausible school workflow (document sharing), and created urgency tied to student outcomes**

○ D. The email was flagged by the spam filter before the teacher saw it

Correct answer: C

Why: Targeted phishing is distinguished from generic spam by the convergence of multiple deliberate elements: domain spoofing for credibility, a pretext relevant to the victim's actual role and context, and engineered urgency, together these show intentional tailoring rather than a mass, indiscriminate blast.

*Why the others are wrong: **A**, Absence of a link doesn't indicate targeting and is in fact inconsistent with this scenario, which centers on a malicious link. **B**, Single-recipient delivery and formal tone alone are weak signals; both legitimate and generic spam emails can share these traits. **D**, Being caught by a spam filter says nothing about how targeted the message was, it's an outcome of delivery, not evidence of intent.*

8. A security awareness trainer is choosing which influence principle to emphasize when teaching staff to resist pretexting calls that impersonate IT support and reference real employee names. Which principle should be prioritized, and why?

○ A. Scarcity, the call implies a limited-time offer the target doesn't want to miss

● **B. Authority, attackers borrow the credibility of a trusted role (IT) combined with insider-sounding detail to suppress the target's instinct to verify**

○ C. Liking, the attacker spends time building a personal friendship before asking for anything

○ D. Social proof, the attacker claims many other employees have already complied

Correct answer: B

Why: Impersonating IT support exploits authority bias: people are conditioned to comply with requests from perceived organizational power or technical expertise, and pairing that with accurate insider details (a manager's name) further suppresses the instinct to independently verify the caller's identity.

*Why the others are wrong: **A**, Scarcity relies on urgency around limited availability, which isn't the mechanism described in an IT-impersonation pretext. **C**, Pretexting calls are typically brief and transactional, not built on cultivated rapport over time. **D**, No claim about other employees' behavior is present in this scenario; the leverage comes from role authority, not peer comparison.*

9. A district is updating its incident-response checklist after several tailgating and pretexting incidents. Which checklist addition would most directly reduce risk across both attack types, given that they exploit different channels (physical vs. verbal)?

○ A. A monthly password rotation policy

○ B. A stronger spam filter on the email gateway

○ C. Mandatory multi-factor authentication on all cloud accounts

● **D. A policy requiring independent verification of any unscheduled request for access or information, regardless of how it arrives**

Correct answer: D

Why: Tailgating and pretexting both exploit human trust and the absence of verification rather than a technical weakness, so the common mitigation that addresses both is a verification-first culture, confirming identity or authorization independently before granting physical access or information, regardless of the channel the request comes through.

*Why the others are wrong: **A**, Password rotation is unrelated to either physical access control or verbal social engineering and doesn't address the root behavioral vulnerability. **B**, Spam filtering only addresses email-based threats and does nothing for in-person tailgating or phone-based pretexting. **C**, MFA protects account logins specifically; it doesn't stop someone from following an employee through a physical door or verbally extracting information.*

10. A company wants receiving mail servers to reject any message that shows the company's domain in the visible From: line but fails sender authentication for that domain. Which DNS-published control does this?

○ A. An SPF record on its own

○ B. A DKIM public-key record

● C. A DMARC record with the policy p=reject

○ D. An MX record

Correct answer: C

Why: DMARC ties the results of SPF and DKIM to the domain in the visible From: line (alignment) and tells receiving servers what to do with mail that fails: nothing (p=none), send it to spam (p=quarantine), or refuse it (p=reject). It is the only one of the four that both checks the address the reader actually sees and states an enforcement policy.

*Why the others are wrong: **A**, SPF lists the servers allowed to send for a domain, but it checks only the envelope sender (MAIL FROM), not the From: line the reader sees, and it does not on its own tell receivers to reject anything. **B**, A DKIM record publishes the public key used to verify a message's signature; by itself it does not link the signature to the visible From: domain or tell receivers to refuse unsigned mail. **D**, An MX record only says which servers accept mail for a domain; it plays no part in checking who sent a message.*

11. An employee is tricked into typing their password and second-factor code into a convincing fake login page that passes everything to the real site in real time. Which kind of multi-factor authentication would still have kept the attacker out?

● A. A FIDO2/WebAuthn security key or passkey registered to the real site's domain

○ B. A six-digit code from an authenticator app

○ C. A one-time code sent by text message

○ D. Security questions about the employee's first school

Correct answer: A

Why: A FIDO2/WebAuthn key is bound to the exact domain it was registered with. On a lookalike domain the browser reports the wrong origin and the key refuses to sign the login challenge, so there is nothing for the fake page to capture and replay. This origin binding is why NIST counts these authenticators as phishing-resistant.

*Why the others are wrong: **B**, An authenticator-app code can be typed into the fake page and replayed to the real site within its 30-second window, which is exactly what happened in the 2020 Twitter attack. **C**, An SMS code is relayed the same way as an app code and is also open to SIM-swap attacks, so it is weaker still. **D**, Security questions are something the user knows, the same factor as a password, and the answers are typed straight into the fake page.*

12. A finance clerk receives an email from a long-standing supplier asking that next week's payment go to a new bank account "because of an urgent audit." Which control is the recommended response?

○ A. Reply to the email and ask the supplier to confirm the new account

○ B. Check that the email carries a valid DKIM signature, then make the change

○ C. Forward the email to a colleague and ask whether it looks genuine

● D. Call the supplier on a phone number taken from the company's own records, not from the email, before changing anything

Correct answer: D

Why: Out-of-band verification, confirming the request through a separate channel whose contact details you looked up yourself, is the control the FBI's IC3 recommends for any change to payment instructions. It works even when the email really comes from the supplier's mailbox because an attacker has taken it over.

*Why the others are wrong: **A**, A reply goes back to whoever controls that mailbox; if the attacker has it, the attacker simply confirms. **B**, A taken-over mailbox at the real supplier signs its mail with the supplier's genuine key, so the DKIM check passes and proves nothing about the request. **C**, A colleague reading the same email has no better evidence than the clerk; in the 2016 DNC case a staffer's quick verdict on a phishing email was exactly what let it through.*

13. An email's headers show the envelope sender MAIL FROM: billing@cheap-mailer.net with SPF passing for cheap-mailer.net, while the visible From: line reads "Jane Doe, CEO" <jane.doe@victim-corporation.com>. Why did SPF not catch this, and which control closes the gap?

○ A. The SPF record for cheap-mailer.net is too loose; making it stricter would stop the message

● **B. SPF checks only the envelope sender, which really was cheap-mailer.net; a DMARC policy on victim-corporation.com requires the authenticated domain to match the visible From: domain**

○ C. SPF only works on encrypted connections; requiring STARTTLS between mail servers would stop the message

○ D. SPF checks the message body rather than the headers; adding DKIM would make it check the From: line instead

Correct answer: B

Why: SPF answers one question: is this server allowed to send for the envelope domain? Here it was, because the attacker controls cheap-mailer.net. The reader, however, sees the RFC 5322 From: line, which SPF never looks at. DMARC closes the gap by requiring that SPF or DKIM pass for a domain aligned with that visible From: domain; mail claiming to be from victim-corporation.com without that alignment is then quarantined or rejected.

*Why the others are wrong: **A**, The attacker writes the SPF record for their own domain, so making it stricter is up to them; SPF passing for cheap-mailer.net is correct behaviour, and the problem is which domain was checked. **C**, STARTTLS encrypts mail in transit but says nothing about who may send as a domain; the spoofed message in the chapter's SMTP transcript was itself sent over TLS. **D**, SPF does not read the body; it compares the sending server's IP address with the envelope domain's list. DKIM signs the message, but on its own it does not require the signing domain to match the From: line.*

14. In the July 2020 Twitter incident, the targeted employees had one-time-password MFA, yet the attackers still signed in to internal admin tools. What explains this, and which change would have stopped it?

○ A. The codes were too short; longer one-time codes would have prevented reuse

○ B. The employees had switched MFA off; enforcing MFA for everyone would have stopped it

● **C. The fake VPN portal collected each code as it was typed and replayed it to the real site before it expired; origin-bound FIDO2 keys would have refused to sign for the fake domain**

○ D. The attackers had broken the one-time-password algorithm; switching to SMS codes would have stopped it

Correct answer: C

Why: The lookalike portal acted as a real-time proxy: it took the username, password and current code and used them on the real site within the code's short validity window. A one-time code proves only that someone has it now, not where it is being typed. FIDO2/WebAuthn keys sign a challenge bound to the genuine domain, so a proxy on a different domain receives nothing it can use.

*Why the others are wrong: **A**, Code length is irrelevant when the victim hands over a valid code; a longer code is relayed just as easily. **B**, MFA was in use; the attack worked around it rather than finding it switched off. **D**, Nothing was cracked, the codes were given away; SMS codes can be relayed the same way and add SIM-swap risk.*

15. A phishing email links to a page that was harmless when the message was delivered at 9:00, but the attacker switches it to a password-harvesting form at 11:00. Which secure email gateway feature is designed for exactly this?

○ A. Attachment sandboxing

○ B. DMARC enforcement

○ C. A banner marking messages from outside the organisation

● **D. URL rewriting that re-checks the link each time it is clicked**

Correct answer: D

Why: URL rewriting replaces each link with one that passes through the gateway, so the destination is evaluated at the moment of the click rather than only at delivery. A page that turned malicious after the message arrived is still caught when the user finally clicks it.

*Why the others are wrong: **A**, Sandboxing opens attachments in an isolated environment to watch their behaviour; this message carries a link, not a file. **B**, DMARC decides whether the sender's domain is authentic; it never examines where a link leads, and a phishing message sent from the attacker's own properly configured domain passes it. **C**, An external-sender banner is a useful cue to slow down, but it does not evaluate the link at all.*

16. A company runs DMARC at p=reject, a secure email gateway, and annual awareness training. A finance employee still wires millions to criminals after an email, sent from the real but taken-over mailbox of a known

business partner, asks for an urgent change of bank details. Which assessment of the company's controls is most accurate?

- **● A. The email controls did what they were built to do, because the message really did come from the partner's domain; the missing layer was a process control requiring out-of-band verification of any payment change**
- ○ B. DMARC failed and should be relaxed from p=reject to p=quarantine so suspicious mail is kept for review
- ○ C. The gateway should have blocked the message, since an email with no link or attachment is itself a sign of fraud
- ○ D. The controls were complete; the fault lies only with the employee, and more frequent training would have been enough

Correct answer: A

Why: Business email compromise from a genuine, compromised mailbox passes SPF, DKIM and DMARC because the mail truly originates where it claims to, and it carries no link or payload for a gateway to flag. That is why the chapter's Toyota Boshoku case calls for an organisational control on top of the technical ones: confirm any change to payment instructions by calling a number looked up independently. The loss came from a missing layer, not from a broken one.

*Why the others are wrong: **B**, The message passed authentication legitimately, so no DMARC policy would have stopped it, and quarantine is a weaker setting than reject, not a stronger one. **C**, Most legitimate business email is plain text with no link or attachment; blocking on that basis would stop normal mail, and it is the absence of a technical signature that makes BEC hard to catch. **D**, Training targets System 1 habits but cannot be relied on alone, especially under urgency and authority pressure; a high-value process with no verification step is an organisational gap.*

17. An organisation that has never published DMARC wants to stop attackers spoofing its domain. The security lead proposes publishing p=reject on day one. Why is the usual rollout to begin at p=none?

- ○ A. A domain may only publish p=reject after it has been registered for a full year
- **● B. At p=none the domain receives reports on every service sending as it, so legitimate third-party senders such as payroll or newsletter platforms can be authenticated before enforcement starts refusing their mail**
- ○ C. p=none blocks spoofed mail more gently by adding a warning banner instead of deleting it
- ○ D. p=reject would also block the mail the organisation receives from other domains

Correct answer: B

Why: DMARC's "R" is reporting. Starting at p=none takes no action on failing mail but shows the domain owner every source sending in its name. Outside services that send on the company's behalf, and are not yet covered by SPF or DKIM, would otherwise be rejected the moment enforcement begins. The usual path is p=none to find them, then p=quarantine, then p=reject.

*Why the others are wrong: **A**, No such waiting period exists; a domain owner can publish any DMARC policy at any time. **C**, p=none takes no action at all on failing mail; it is monitoring only, and banners are a gateway feature, not a DMARC policy. **D**, A DMARC policy governs mail that claims to come from the publishing domain; it has no effect on mail the organisation receives from anyone else.*

18. After a vishing campaign in which callers posed as IT support and talked staff into "updating VPN settings" on a lookalike portal, a company wants layered controls that each break a different step of the attack. Which set does this best?

- ○ A. Longer passwords, quarterly password changes, and a company password manager
- ○ B. A stricter spam filter, DMARC at p=reject, and attachment sandboxing
- **● C. A rule that IT never asks for credentials by phone, with staff calling back on the published helpdesk number; FIDO2 keys for VPN and admin sign-in; and admin tools limited to the few people who need them**
- ○ D. A yearly awareness video and phishing posters in every office

Correct answer: C

Why: Each layer stops a different step. The call-back rule removes the authority pretext, because staff verify through a channel they chose. FIDO2 keys mean credentials typed into the lookalike portal cannot be used on the real site. Least privilege on admin tools limits what one compromised account can reach; in the 2020 Twitter case those tools let the attackers take over high-profile accounts.

*Why the others are wrong: **A**, Password strength does not matter when the victim types the password into the attacker's page; none of these controls address the phone call or the stolen session. **B**, These are email controls, and the attack arrived by phone and a web portal; none of them touch either channel. **D**, Awareness alone is a single layer with no technical backstop, and one hurried employee is enough for the attack to succeed.*